

Oversight of Notification of Breach of Personal Data Security

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Notification of Breach of Personal Data Security

The Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-41-0133.

Spar Nord Bank A/S (hereinafter Spar Nord Bank) was among the companies that the Data Protection Agency selected for supervision in the autumn of 2021 following the General Data Protection Regulation[1] and the Data Protection Act[2].

The Data Protection Agency's supervision was a written inspection that focused on whether Spar Nord Bank had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, with the aim of reducing the number of breaches of personal data security, where unauthorized disclosure of personal data occurred, including confidential information, particularly in relation to financial information.

The inspection was announced to Spar Nord Bank by letter dated November 24, 2021, and the bank was simultaneously requested to respond to a number of questions and to submit an example of an instruction to the bank's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc.

The Data Protection Agency informed about the background for the inspection, noting that a review of the Agency's cases regarding notifications of breaches of personal data security revealed that Spar Nord Bank had reported significantly more breaches of personal data security per employee in the financial institution than other financial institutions. The Data Protection Agency noted in this context that the higher number of notifications does not necessarily indicate that the bank complies with data protection regulations to a lesser extent than financial institutions that have significantly fewer notifications per employee.

By letter dated January 14, 2022, Spar Nord Bank sent a statement in which the bank responded to the Data Protection Agency's questions. Spar Nord Bank's response was also accompanied by examples of relevant instructions and guidelines, etc.

Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of eight larger municipalities and eight larger banks' handling of breaches of personal data security.

The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipalities' population and the number of employees in the bank, respectively.

"One of the new things that came with GDPR over five years ago was that data controllers, as a rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, Chief Consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is largely that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had implemented appropriate security measures to reduce the

number of breaches of personal data security, where unauthorized disclosure of personal data occurred in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons. The data controller must, in this context, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found on the basis of the present material that all data controllers had implemented appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been conducted to educate employees in data protection, including to ensure that they are aware that there is no accidental disclosure of personal data to the wrong parties.

recipient.

They have considered and continuously implemented both technical and organizational measures in response to past breaches of personal data security to avoid similar breaches. There is a strong focus on preventing the unintended disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., as well as systematic measures, etc.

****Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this regard, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are detected within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with.

Therefore, data controllers should document their justifications for all significant decisions made as a

result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there has been pronounced criticism in two of the cases – specifically concerning two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the registered security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of what types of breaches typically occur within the organization, and based on that, to consider whether, from a risk assessment perspective, there is a need to implement new or additional measures to avoid or further reduce the risk of additional breaches. It is also indicated in the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds on the basis of the present information that Spar Nord Bank has implemented appropriate security measures in accordance with Article 32, paragraph 1, of the General Data Protection Regulation, aimed at reducing the number of breaches of personal data security where unauthorized disclosure of personal data occurs, including confidential information, particularly in relation to financial information.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It is stated in Article 32, paragraph 1, of the General Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security that is appropriate to the risks associated with the data controller's processing of personal data.

The data controller thus has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks.

It is the opinion of the Data Protection Authority that the requirement in Article 32 for appropriate security will generally entail that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons, and that in this regard, the data controller must ensure that all employees in the organization are adequately familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

Spar Nord Bank has, in its statement of January 14, 2022, submitted a guide on secure communication (Appendix 1) as well as excerpts from the bank's GDPR site and IT security policy (Appendices 2 and 3). The bank has also submitted guidelines for training employees in personal data, excerpts from the bank's employee handbook, the bank's data protection advisor's introductory material for new employees, and a copy of an email regarding the results of a Data Loss Prevention scan (Appendices 4 – 7).

Spar Nord Bank has initially stated, among other things, that the bank – in relation to the period from May 25, 2018, until the end of 2020 – has adjusted its reporting procedure regarding data breaches, as the bank has conducted a renewed assessment of when a breach of personal data security should be reported to the authority. In the aforementioned period, the bank reported almost all breaches, regardless of whether a more detailed risk assessment might have shown that it was unlikely that the breach of personal data security posed a risk to the rights or freedoms of natural persons. From early/mid-2021, the bank has adjusted the process and risk assessment for handling data breaches, which has resulted in fewer reports to the authority. However, the bank continues to have a restrictive practice regarding when breaches are reported to the Data Protection Authority. This is due to the bank's increased focus on the protection of customers' personal data, particularly due to the heightened confidentiality obligation that Spar Nord Bank, as a financial institution, is subject to.

Spar Nord Bank has further stated that the bank has prioritized a high degree of awareness regarding data breaches, and that there is a clear process for handling data breaches as well as a visibly placed form for reporting data breaches on the intranet, which means that employees internally have relatively easy access to report breaches of personal data security.

Spar Nord Bank has stated that the bank's data protection policy sets out some overarching principles regarding the bank's handling of personal data, which are implemented in a wide range of areas related to the bank's handling, including that all of the bank's employees have a duty of attention in the work they perform, ensuring that personal data about the bank's customers and employees is processed in accordance with the bank's rules and business procedures.

It has also been stated that the bank has implemented a GDPR site that consolidates knowledge about data protection regulations, allowing the bank's employees to easily and quickly seek information. The site contains guidance on secure communication. The guidance is the bank's instruction to employees on how to communicate securely with the bank's customers. It states, among other things, that the starting point is that communication with customers occurs via online banking. If this is not possible, TLS-encrypted emails may be used.

On the GDPR site, there is also a separate section on breaches of personal data security, which states, among other things, that the majority of the bank's data breaches relate to misdirected emails or documents sent to the wrong recipient. It is noted that employees are advised to double-check the recipient and content of a message and possibly ask a colleague to review the email before sending it to avoid these types of errors.

It has further been stated that the IT security policy includes a chapter on communication security, which states that communication must occur with appropriate security measures. For electronic communication to external parties, there is a requirement for encryption, as well as the need for due diligence to ensure confidentiality requirements are met.

It is also indicated in the submitted material that e-learning training for employees is conducted every other year, both regarding data protection in general and regarding awareness of breaches of personal data security. Additionally, the bank's DPO participates in introductory days for new employees, which are held once a month. The DPO's material includes, among other things, posters related to data breaches, including ensuring sufficient attention when transmitting information.

Spar Nord Bank has stated that the heightened confidentiality obligation, as mentioned above, is fundamental to the bank's work, and that the requirement for confidentiality is communicated to the bank's employees upon hiring, as well as being included in the employee handbook. It is therefore naturally embedded in the bank's work and the handling of customer information that the confidentiality of the information must be ensured.

Spar Nord Bank has further stated that GDPR risk assessments are prepared, cf.

****Article 32 of the Data Protection Regulation****, both in relation to systems and the processing activities themselves. This includes an assessment of the risk of breaches of confidentiality in connection with the processing of personal data. As part of the assessment, the threat is described, as

well as the measures – both technical and organizational – that have been implemented or are to be implemented to protect the personal data being processed and to reduce the risk of breaches of confidentiality.

Spar Nord Bank has finally stated that the bank has considered past breaches of personal data security, where there has been an unintentional disclosure of personal data. Based on these considerations, the bank has continuously implemented organizational measures, including maintaining statistics on the types of breaches of personal data security to identify the need for additional security measures and conducting targeted awareness in departments where there are more breaches of personal data security than in others. The bank has also implemented technical measures, such as a Data Loss Prevention solution, which scans for confidential information and alerts the employee before an email is sent to an external recipient. Additionally, Spar Nord Bank has planned to implement further measures in 2022, including a GDPR awareness campaign with a particular focus on breaches of personal data security.

It is – notwithstanding that the Data Protection Agency has not had the opportunity to take a concrete position on whether all relevant employees have completed the relevant training activities, etc., and that the agency is not aware of the full content of all guidance and training materials – based on the present information, the agency's assessment is that Spar Nord Bank has taken appropriate security measures in accordance with Article 32, paragraph 1 of the Data Protection Regulation, with the aim of reducing the number of breaches of personal data security, where there is unauthorized disclosure of personal data, including information of a confidential nature, particularly in relation to financial information.

In its assessment, the Data Protection Agency has emphasized the information provided by Spar Nord Bank, including that procedures, etc., have been developed and activities have been carried out to educate employees in data protection, including to ensure that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient, that Spar Nord Bank has considered and continuously introduced both technical and organizational measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on preventing unintentional disclosure of personal data, which is supported by business processes, ongoing guidance, etc., and systematic initiatives aimed at creating secure communication channels between the bank's employees and customers.

The Data Protection Agency can, upon a renewed review of the agency's cases regarding reports of breaches of personal data security, ascertain that since November 24, 2021, there has been a decrease in the number of reported breaches of personal data security from Spar Nord Bank. However, as a number of breaches of personal data security continue to be reported, where there has been unauthorized disclosure of personal data, the Data Protection Agency recommends that the bank continues to focus on implementing training and awareness activities, etc., and to ensure that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

Finally, the Data Protection Agency notes that the agency – typically if it receives new reports of breaches of personal data security – may resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)